

ICT Technical Review & Compliance Checklist

Audit Tool for Dirt Trails Safaris Platform

Executive Summary: This technical review and compliance checklist has been constructed to evaluate the legal, security, and operational readiness of the integrated digital tourism platform under Uganda's regulatory jurisprudence. Aligned with the Digital Uganda Vision and the Digital Transformation Roadmap 2023/24-2027/28 championed by the Ministry of ICT and National Guidance, this document operationalizes compliance assessments across five regulatory categories. It serves as a rigorous self-audit and administrative verification tool for platforms connecting travelers with local transport, accommodation, and tour operators.

Checklist Item & Regulatory Grounding	Compliance (Y/N)	Auditor Comments & Evidence
Category 1: National ICT Policies, Laws & Regulatory Requirements		
Are electronic contracts, bookings, and customer agreements validated to ensure legal recognition under the Electronic Transactions Act, 2011 ?	[] Yes [] No	
Are non-repudiable digital signatures integrated for high-value tour operator and B2B vendor agreements per the Electronic Signatures Act, 2011 ?	[] Yes [] No	
Does the platform maintain system-level audit logs and access controls to prevent and trace electronic fraud under the Computer Misuse Act, 2011 ?	[] Yes [] No	
Is the non-resident operating entity registered for the 5% Digital Services Tax (DST) on B2C services (Income Tax Act Sec 86A)?	[] Yes [] No	
Does the system withhold a 15% Withholding Tax (WHT) on non-resident associated/related entity digital transactions where applicable?	[] Yes [] No	
Is the platform configured to charge and quarterly remit the 18% Value Added Tax (VAT) on electronic supplies to Ugandan consumers?	[] Yes [] No	
Category 2: Cybersecurity Requirements & Recommended Measures (NISF 2026)		
Is senior leadership accountability implemented, with the Board/Accounting Officers formally owning institutional cyber risks (NISF 2026 Principle 1)?	[] Yes [] No	
Are boundary and endpoint protection standards met through enterprise-grade firewalls and Intrusion Detection/Prevention Systems (IDS/IPS) ?	[] Yes [] No	
Is a SIEM (Security Information & Event Management) tool deployed to analyze security logs across all platform components in real-time?	[] Yes [] No	

Checklist Item & Regulatory Grounding	Compliance (Y/N)	Auditor Comments & Evidence
Are regular, documented vulnerability assessments and penetration tests scheduled and conducted to proactively identify vulnerabilities?	☐ Yes ☐ No	
Is a formal Incident Response Plan documented, tested at least once a year, and linked with reporting protocols to the National CERT/CC ?	☐ Yes ☐ No	
Is infrastructure redundancy enforced for critical booking/payment databases (including redundant power UPS, dual feeds, and RAID storage)?	☐ Yes ☐ No	
Is a verified IT asset register maintained, with strict data sanitization and wiping protocols enforced prior to hardware disposal?	☐ Yes ☐ No	
Category 3: Data Protection, Privacy & Information Security Compliance (DPPA 2019)		
Is the platform formally registered as a data controller/processor with the Personal Data Protection Office (PDPO) with annual renewal?	☐ Yes ☐ No	
Is the designated Data Protection Officer (DPO) appointed, qualified, and registered with the PDPO to oversee traveler and operator data?	☐ Yes ☐ No	
Are informed consent mechanisms designed using active affirmative actions (e.g. unticked boxes), explicitly stating third-party data recipients?	☐ Yes ☐ No	
Are age-verification mechanisms and parental/guardian consent workflows active for travelers under the age of 18?	☐ Yes ☐ No	
Is there an active incident tracking protocol configured to trigger breach notifications to the PDPO within 48 hours of awareness?	☐ Yes ☐ No	
For cloud storage outside Uganda (e.g. AWS/Azure), has a Data Protection Impact Assessment (DPIA) been filed to prove equivalent protection?	☐ Yes ☐ No	
Are technical measures (including AES-256 encryption at rest, TLS 1.3 in transit, and role-based access controls) fully operational?	☐ Yes ☐ No	
Are third-party processor agreements legally structured to enforce DPPA compliance and data confidentiality on all sub-contractors?	☐ Yes ☐ No	
Category 4: Digital Service Standards, Accessibility & Interoperability (e-GIF / UGHub)		
Does the web and mobile platform comply with WCAG 2.0/2.2 AA standards (including screen-reader compatibility and contrast ratios)?	☐ Yes ☐ No	
Does the system support up to 400% text resizing and full keyboard operability for travelers with motor or visual impairments?	☐ Yes ☐ No	
Are system APIs aligned with the e-Government Interoperability Framework (e-GIF) using standardized XML or JSON data structures?	☐ Yes ☐ No	
Is the system technically integrated with the WSO2-powered UGHub platform to enable real-time federated data exchange?	☐ Yes ☐ No	
Does the integration use central API gateway controls including OAuth 2.0 authentication, rate-limiting, and centralized logging?	☐ Yes ☐ No	

Checklist Item & Regulatory Grounding	Compliance (Y/N)	Auditor Comments & Evidence
Category 5: Administrative Approvals, Registrations & Collaboration Permissions		
Has the platform's operating IT provider obtained a valid NITA-U Conformity Certificate (Level 1, 2, or 3) under the 2016 Regulations?	☐ Yes ☐ No	
Is an active MoU or SLA established with the National Identification and Registration Authority (NIRA) for real-time e-KYC NIN checks?	☐ Yes ☐ No	
Is an integration MoU established with Uganda Revenue Authority (URA) for automated TIN checks and EFRIS electronic invoicing?	☐ Yes ☐ No	
Is there a formal data-sharing SLA with the Uganda Wildlife Authority (UWA) to securely automate gorilla and park permit bookings?	☐ Yes ☐ No	
Is there a verified linkage with the Directorate of Citizenship and Immigration Control (DCIC) to check e-Visa status for international guests?	☐ Yes ☐ No	
Have the platform's legal and privacy documents been verified through NITA-U's online Regulatory Compliance Portal (compliance.nita.go.ug)?	☐ Yes ☐ No	

CATEGORY 1 - ELECTRONIC BOOKING AGREEMENTS

Checklist answer: No - legal validation is still required.

Assessment date: 24 September 2026

Implemented

- Booking and ticket payment paths present an unticked agreement choice linked to the DirtTrails Terms of Service.
- The live database stores terms version 2026-09-24, a server timestamp, and the accepting Auth identity.
- The agreement RPC records acceptance; direct edits to acceptance fields are blocked.
- Private anonymous Auth sessions restore guest checkout while RLS keeps each order and booking private.

Evidence and verification

- Frontend: termsAcceptance.ts, termsVersion.ts, BookingRepository.ts, and ticket payment flows.
- Database: booking_terms_acceptance and secure_guest_checkout migrations; live ownership and acceptance tests passed.
- Production build passed. A second guest could not read the test booking or order.

Remaining limits

- This is an affirmative click record, not a digital signature or independent identity proof.
- Legal counsel must assess recognition under the cited Act and approve the terms text.
- Two paid bookings still require MarzPay reconciliation before integrity sign-off.

CATEGORY 1 - DIGITAL SIGNATURES FOR VENDOR AGREEMENTS

Checklist answer: No - no non-repudiable signing flow exists.

Assessment date: 24 September 2026

Current state

- Vendor registration has a terms checkbox, but this does not sign a specific operator or B2B agreement.
- The code search found no agreement signing, document hash, signer verification, or signature validation workflow.
- The live public schema has no agreement, contract, or signature table and no signed-agreement columns.

Evidence

- Frontend: VendorLogin.tsx contains vendorAgreeTerms; vendor onboarding and admin vendor pages have no signing step.
- Live Supabase schema inspection found no stored signature evidence or agreement version tied to a vendor.

Required before marking Yes

- Approve a versioned vendor agreement and define which high-value/B2B transactions require it.
- Bind the verified vendor signatory to that exact document; record a tamper-evident signed artifact and audit trail.
- Block agreement-dependent vendor activation until signing completes; obtain legal review of the chosen method.

CATEGORY 1 - AUDIT LOGS AND ACCESS CONTROLS

Checklist answer: No - comprehensive fraud audit trail absent.

Assessment date: 24 September 2026

Controls implemented and tested

- RLS now covers all public tables, including login history, messages, OTPs, activation requests, and configuration.
- Users can read only their own login history or messages. A trigger blocks edits to message content and participants.
- Public catalog reads still work; public fee-configuration writes and direct ticket issuing/redemption are blocked.
- Ticket redemption is exposed only through an owning-vendor/admin RPC; guest OTP-based scanning is paused.
- Profile and vendor triggers now reject anonymous admin-role creation and owner changes to approval status.

Evidence

- Live anonymous API tests returned zero rows for five sensitive tables; 7 categories and 74 ticket types remained readable.
- Public fee writes and ticket-issuance/redemption RPC calls were rejected. TypeScript and production build passed.
- A live anonymous attempt to create an admin profile was rejected. Four security migrations were applied.

Remaining gaps before Yes

- Login history contains 669 records with user agents, but no recorded IP addresses; Auth audit_log_entries has zero rows.
- No dedicated change audit triggers cover bookings, orders, payments, transactions, or vendor actions.
- Vendor-owned update policy still permits tier/financial-field edits; financial integrity review is required before changing it.
- No verified central retention, tamper protection, alerting, or incident review process covers these events.

CATEGORY 3 - INFORMED CONSENT

Checklist answer: Yes - application consent mechanisms implemented.

Applies to new app signups and booking/order checkout, including guests.

Assessment date: 24 September 2026

Criterion assessed

- Are informed consent mechanisms designed using active affirmative actions, explicitly stating third-party data recipients?

Controls implemented

- All three application signup forms require a separate, initially unticked privacy acknowledgement.
- Every booking or ticket checkout now requires separate unticked terms and privacy choices before booking creation or payment preparation, including guest sessions.
- The notice names the service vendor, MarzPay for paid bookings, and Supabase for hosting; it clarifies that restaurant reservations are not charged.
- New signup consent and per-booking/order consent are recorded with server timestamps and notice versions in protected tables.

Verification and limits

- Live RLS and RPC privileges block public writes. A rollback owner test recorded checkout consent; an unrelated actor was rejected. TypeScript passed.
- Historical accounts and bookings are not retroactively marked as consented. The Yes answer covers the application-controlled flows, not direct Auth API calls outside the UI.
- Two older paid bookings still lack linked payment rows; this consent change did not alter amounts, payment status, wallets, or settlement.

CATEGORY 3 - AGE AND GUARDIAN CONSENT

Checklist answer: No - adult-only signup is an attestation.

Independent age verification and guardian consent are not active.

Assessment date: 24 September 2026

Criterion assessed

- Are age-verification mechanisms and parental/guardian consent workflows active for travelers under 18?

Code changes completed

- The operating policy is adult-owned accounts: families may book through an adult; people under 18 may not create accounts.
- Tourist page, tourist modal, and vendor signup now require an initially unticked 18+ confirmation, enforced in the shared signup function.
- Account signup metadata records an adult-confirmation timestamp, and the Privacy Policy now consistently states the 18+ account rule.

Verification and remaining work

- TypeScript check passed, and all three application signup entry points call the shared guard.
- Self-attestation does not independently verify age; direct Auth API registrations can bypass the application form.
- No parental/guardian consent flow exists because minors cannot hold accounts under the selected policy. The requested criterion therefore remains No.